

CITY UNIVERSITY OF HONG KONG

Course code & title : CS5285 Information Security for eCommerce

Session : Semester B 2003/04

Time allowed : Two hours

This paper has **SIX** pages (including this cover page).

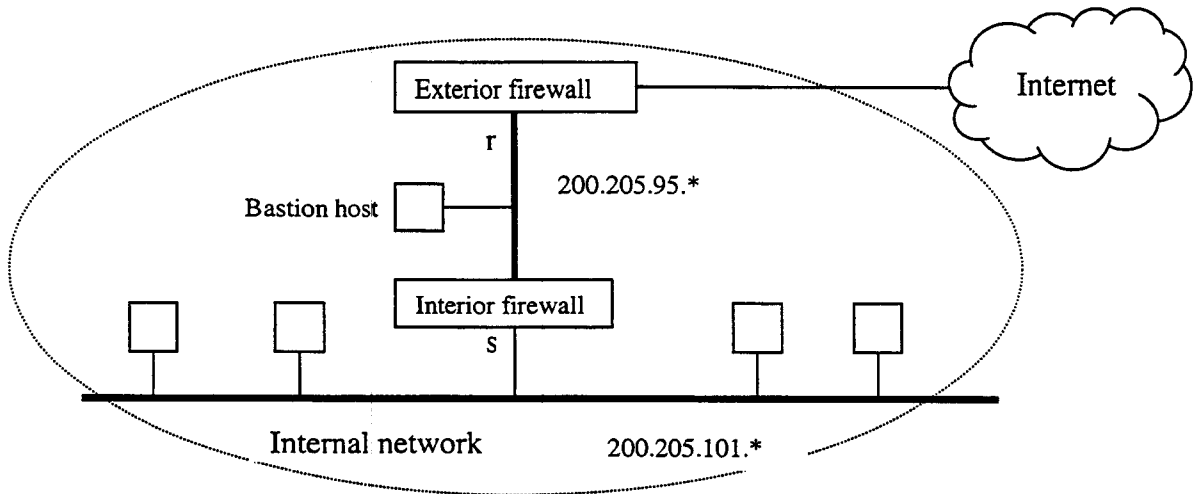
1. This paper consists of five questions.
 2. Attempt any FOUR out of the five questions.
-

Materials, aids & instruments permitted to be used during examination:

Approved Calculator

Question 1 (25 marks)

(a) Consider the following firewall configuration:



The network ID of the perimeter network and the protected internal networks are 200.205.95.* and 200.205.101.*, respectively. And the bastion host has IP address 200.205.95.12.

- (i) Suppose a web server is set up for incoming access. Where should it be placed?
(ii) If we want to filter traffic as follows:

- Incoming web access (to the web server in (i)) with SSL is allowed
- Outgoing access to external web service from the internal network is allowed.
- TCP connections initiated from the internal network to perimeter network are allowed
- All other traffic are denied.

Write filters with respect to ports r and s to effect the above.

- (iii) If a dial-in remote access server machine (RAS) is to be added, where should it be placed? Briefly explain.
(iv) Suppose access to the dial-up RAS above are mostly through long-distance calls and the charges are high, briefly describe a more cost effective configuration. You may replace the RAS server machine in your suggestion.

[21 marks]

- (b) Do you think traffic restriction control based on packet filtering can solve all malicious intrusions to an organization's network? Explain your answer.

[4 marks]

Question 2 (25 marks)

- (a) Suppose a 64-bit hash function is used to produce a signature: $D_A(h(P))$, where P is the document for which the signature $X = D_A(h(P))$ is produced. What is the probability that X is a signature of a different document P' ? How many documents an attacker need to go through, on the average, to find 2 documents that have the same signature? Comment on the adequacy of using a 64-bit hash in a digital signature scheme.

[8 marks]

- (b) Propose a protocol for sending a message m from Alice to n participants $P_1, P_2, \dots, P_n$, in encrypted form with signature using hybrid encryption (say RSA with DES). The protocol should be such that the effort of encryption is minimized. In your scheme, what is the number of times you apply symmetric encryption and what is the number times you apply asymmetric encryption?

[9 marks]

- (c) If in the above scheme, a 2048-bit RSA key and a 56-bit IDEA key are used. Estimate the amount of effort in mips-years that is required to break the encrypted message? Show your calculations.

(You may assume that one operation = 1 instruction, and that if brute force attack is used, trying one key takes 100 operations)

[8 marks]

Question 3 (25 marks)

- (a) When you submit your magnetic strip bankcard for purchasing in a shop using EPS, is it possible that your account information and PIN be stolen? Explain your answer. You may assume that all communications (between EPS reader and bank) are securely protected and that no one is looking over your shoulder.

[5 marks]

- (b) Consider the following challenge-response authentication protocol based on secret key encryption. The server generates a random string n and sends it as a challenge to the client. The client encrypts the challenge and uses it as the response. The encryption is done with a secret key k shared by the client and the server. For each of the following cases, say whether the authentication protocol is secure and briefly explain your answer.

- (i) In a contactless smartcard system for public transport, the encryption function E used is a Feistel cipher which is resistant to known plaintext attack. That is, $\text{response} = E_k(n)$.

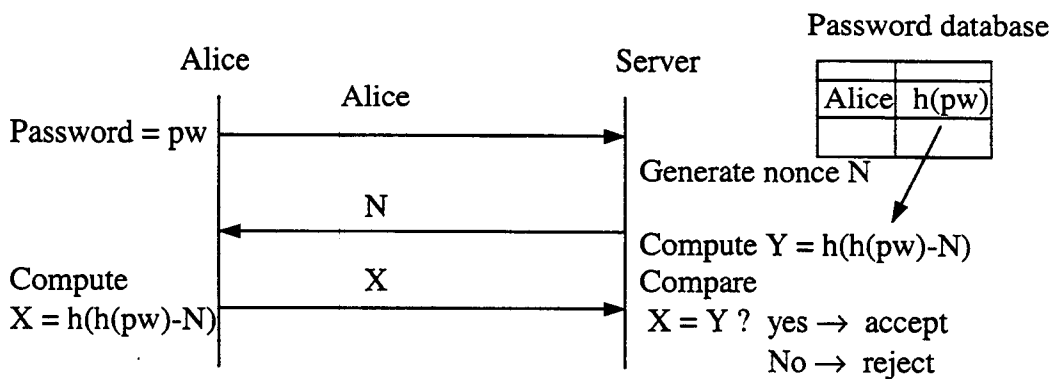
(ii) In 802.11 WEP, the encryption function used (in its shared key authentication scheme) is exclusion OR. That is, $\text{response} = k \oplus n$.

(iii) The encryption is replaced by the hash of the challenge concatenated with the secret key. That is, $\text{response} = h(n \parallel k)$. Where h is a publicly known hash function such as SHA-1.

(For this question, you may assume that the key size is adequate to resist brute force attack, and that man-in-the-middle attack is not feasible).

[12 marks]

- (c) We have seen that, without using public key encryption, it is difficult to design an authentication protocol that protects against both eavesdropping and server password database disclosure. Consider the following protocol first used in Novell version 3 security, and adopted for Microsoft's IIS.

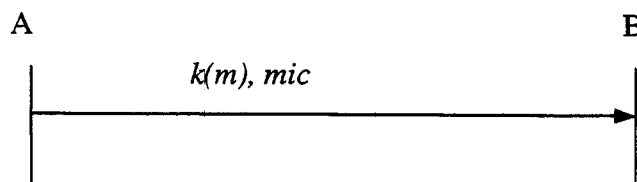


Alice sends her userid. The server generates a challenge N . Alice (actually her computer) calculates the response X using her password and the challenge as above. Assume that the hash function h is known by Alice and the Server. Is this authentication protocol safe against both eavesdropping and password database disclosure? Explain.

[8 marks]

Question 4 (25 marks)

- (a) Consider the following protocol intended to implement message integrity protection. That is, the receiver should be able to detect if the message m has been tampered.



The message integrity code is calculated $mic = h(m)$. $k(m)$ indicates the encryption of m with key k , which is a secret key known only to A and B, and h is a publicly known hash function. Briefly describe a major weakness of this protocol if the number of possible messages is small. How can this weakness be remedied by using initialization vectors? Show the revised protocol.

[7 marks]

- (b) Suppose you are presented with Bob's X.509 digital certificate over the Internet.
- (i) How can you decide if the certificate is valid and trust worthy?
 - (ii) Can you be sure that the presenter of the certificate is actually Bob? If so, explain. If not, what additional step you can take to make sure?

[10 marks]

- (c) Does S/MIME enveloped message provide for message integrity? Explain. Does S/MIME signed message provide for message integrity? Explain.

[8 marks]

Question 5 (25 marks)

- (a) Name and briefly describe the approach taken by the Java model to limit damage by downloaded code.

[5 marks]

- (b) For each of the following payment scheme, briefly explain if the scheme provide for payer anonymity. That is, explain if the PSP can trace the payer's identity.

Credit card over SSL

Octopus card (normal type)

Lottery micropayment scheme

[9 marks]

- (c) Suppose a user browser's current url is www.website.com and a form is presented:

```
<FORM method="GET" action="cgi-bin/prog.cgi">
Please input your user id:
<INPUT type="text" name="userid" size=8><br>
Card number:
<INPUT type="text" name="cardnumber"><br>
<p>Please make your choice:
.....
.....
<INPUT type="submit">
</FORM>
```

- (i) Briefly describe 2 security weaknesses that you can observe. Modify the above to remove or reduce the security weaknesses.
- (ii) Suppose after submission of the above form (unmodified version), the response page contains an automatic reference to another site www.dddc.com:

```
<html>
<head><title>website.com response</title></head>
<body>
<h2>Thank you for your business</h2>
<p>
.....
<IMG SRC="http://www.dddc.com/poster.gif">
.....
</body></html>
```

is there any security risk with the above response page? Briefly explain your answer.
[11 marks]

*** END ***